

HERRAMIENTAS DE PROGRAMACIÓN WEB DEL SERVIDOR

Tema 4 — Seguridad y Buenas Prácticas en Programación Web

OWASP Top 10 y Buenas Prácticas

Riesgos críticos, contramedidas y codificación segura

1. ¿Qué es OWASP?

OWASP (Open Worldwide Application Security Project) es una fundación sin ánimo de lucro dedicada a mejorar la seguridad del software. Entre sus proyectos más conocidos se encuentra el OWASP Top 10, un documento de referencia que resume los diez riesgos de seguridad más críticos en aplicaciones web, elaborado a partir del análisis de datos reales de vulnerabilidades reportadas por organizaciones de todo el mundo (OWASP Foundation, 2021). Se actualiza periódicamente para reflejar la evolución de las amenazas y sirve como guía tanto para desarrolladores como para auditores de seguridad.

2. OWASP Top 10 y sus contramedidas

La siguiente tabla resume, de forma orientativa, las diez categorías de riesgo y las principales medidas para mitigarlas:

Riesgo	Descripción	Contramedida principal
A01	Pérdida de control de acceso (Broken Access Control)	Aplicar el principio de mínimo privilegio, verificar permisos en el servidor en cada petición y denegar por defecto.
A02	Fallos criptográficos (Cryptographic Failures)	Cifrar datos sensibles en tránsito (TLS) y en reposo, usar algoritmos actualizados y no almacenar contraseñas en texto plano.
A03	Inyección (Injection)	Usar consultas parametrizadas o ORM, validar y sanear toda entrada de usuario, evitar concatenar código dinámico.
A04	Diseño inseguro (Insecure Design)	Incorporar modelado de amenazas y requisitos de seguridad desde las fases iniciales del diseño.
A05	Configuración de seguridad incorrecta	Eliminar cuentas y servicios por defecto, aplicar bastionado (hardening) y mantener el software actualizado.
A06	Componentes vulnerables y desactualizados	Inventariar dependencias, aplicar parches y usar herramientas de análisis de vulnerabilidades (SCA).
A07	Fallos de identificación y autenticación	Implementar autenticación multifactor, políticas de contraseñas robustas y control de intentos fallidos.
A08	Fallos de integridad de software y datos	Verificar firmas digitales, usar pipelines de CI/CD seguros y controlar el origen de las dependencias.
A09	Fallos de registro y monitorización	Registrar eventos de seguridad relevantes, centralizar logs y establecer alertas ante actividad sospechosa.
A10	Server-Side Request Forgery (SSRF)	Validar y limitar las URLs a las que el servidor puede acceder, usando listas blancas de destinos permitidos.

Aunque el orden y la redacción exacta de cada categoría pueden variar entre versiones del documento, el objetivo se mantiene: ofrecer una lista priorizada que ayude a los equipos de desarrollo a enfocar sus esfuerzos de seguridad en los riesgos con mayor impacto y frecuencia real (OWASP Foundation, 2021).

3. Buenas prácticas de codificación web

Más allá de conocer los riesgos del OWASP Top 10, es fundamental incorporar hábitos de codificación segura en el día a día del desarrollo. A continuación se presentan las prácticas más relevantes:

3.1 Validación y saneamiento de entradas

- **Validar en el servidor:** nunca confiar únicamente en la validación realizada en el cliente (JavaScript), ya que puede eludirse fácilmente.
- **Listas blancas:** preferir la validación por listas blancas (qué se permite) frente a listas negras (qué se bloquea).
- **Escapado de salida:** codificar correctamente los datos antes de mostrarlos en HTML, JavaScript o consultas SQL para evitar inyecciones.

3.2 Gestión segura de la autenticación y sesiones

- **Contraseñas:** almacenar siempre con funciones de hash específicas para contraseñas (bcrypt, Argon2), nunca en texto plano ni con hash simple, siguiendo recomendaciones como las de NIST SP 800-63B (National Institute of Standards and Technology, 2020).
- **Cookies de sesión:** usar los atributos HttpOnly, Secure y SameSite para reducir el riesgo de robo de sesión (OWASP Foundation, s. f.).
- **Expiración y renovación:** establecer tiempos de expiración razonables y regenerar el identificador de sesión tras el inicio de sesión.

3.3 Cifrado y protección de datos

- **HTTPS obligatorio:** forzar el uso de TLS en toda la aplicación, redirigiendo automáticamente el tráfico HTTP (Mozilla, s. f.).
- **Cifrado de datos sensibles:** proteger en la base de datos la información especialmente sensible (datos personales, tarjetas, tokens), en línea con lo exigido por el RGPD (Parlamento Europeo y Consejo de la Unión Europea, 2016).
- **Gestión de secretos:** no incluir contraseñas, claves de API o tokens directamente en el código fuente ni en el repositorio.

3.4 Control de acceso y principio de mínimo privilegio

- **Verificación en cada petición:** comprobar permisos en el servidor para cada acción, no solo al iniciar sesión.
- **Denegar por defecto:** cualquier recurso debe ser inaccesible salvo que exista una regla explícita que lo permita.

3.5 Manejo de errores y registro de eventos

- **Mensajes de error genéricos:** evitar mostrar al usuario detalles técnicos (rutas, versiones, trazas de pila) que puedan ayudar a un atacante.
- **Registro (logging):** registrar eventos de seguridad relevantes (accesos fallidos, cambios de permisos) sin almacenar datos sensibles en los logs.

3.6 Actualización y gestión de dependencias

- **Mantener el software actualizado:** aplicar parches de seguridad del framework, del servidor y de las librerías utilizadas.
- **Auditoría de dependencias:** revisar periódicamente las librerías de terceros en busca de vulnerabilidades conocidas.

4. Conclusión

La seguridad en aplicaciones web no es un producto final, sino un proceso continuo que debe integrarse en todas las fases del desarrollo: diseño, codificación, pruebas y mantenimiento. Conocer los riesgos descritos en el OWASP Top 10 y aplicar de forma sistemática las buenas prácticas de codificación segura permite reducir drásticamente la probabilidad de sufrir un incidente de seguridad, protegiendo tanto a la organización como a los usuarios finales de la aplicación.

Referencias bibliográficas

- Mozilla. (s. f.). Web Security Guidelines. Mozilla Infosec. https://infosec.mozilla.org/guidelines/web_security
- National Institute of Standards and Technology. (2020). Digital Identity Guidelines: Authentication and Lifecycle Management (NIST SP 800-63B). U.S. Department of Commerce. <https://csrc.nist.gov/pubs/sp/800/63/b/upd2/final>
- OWASP Foundation. (2021). OWASP Top 10:2021 — The ten most critical web application security risks. <https://owasp.org/Top10/2021/>
- OWASP Foundation. (s. f.). OWASP Cheat Sheet Series. <https://cheatsheetseries.owasp.org/>
- Parlamento Europeo y Consejo de la Unión Europea. (2016). Reglamento (UE) 2016/679, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales (RGPD). Diario Oficial de la Unión Europea, L 119. <https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=celex%3A32016R0679>
- Stuttard, D., & Pinto, M. (2011). The Web Application Hacker's Handbook: Finding and Exploiting Security Flaws (2.ª ed.). Wiley.